

SIMATS ENGINEERING

ASSESSMENT TOOL 2

VULNERABILITY ASSESSMENT REPORT

Annexure A – Case Study 7: Wi-Fi Attacks Against Anti-Doping Officials, 2016

Course Name	Ethical Hacking
Course Code	ITA14
Course Outcome	CO4 – Implement network security testing methods by performing web server attacks, analysing web application vulnerabilities, and assessing wireless network security using Kali Linux.
Student Name	Pranov Raaj G
Register Number	192372355

1. Incident Background and Technical Understanding

According to a 2018 indictment filed by the United States Department of Justice, members of a foreign military intelligence unit conducted “close access” cyber operations against anti-doping and sporting organizations' between 2014 and 2018. Among the alleged operations, close-access teams targeted the Wi-Fi networks used by anti-doping officials attending events in Rio de Janeiro, Brazil (2016 Olympic Games) and Lausanne, Switzerland (home of several international sporting federations and the Court of Arbitration for Sport).

Close-access operations differ from remote cyberattacks in that operatives physically position themselves near the target — typically in the same hotel, conference venue, or adjoining premises — in order to intercept, spoof, or otherwise compromise the wireless networks that victims are already using. In this case, hotel and venue Wi-Fi networks used by travelling officials, doping-control personnel, and medical staff were the primary attack surface.

The threat actor is assessed to be a state-sponsored advanced persistent threat (APT) group with the operational capability to conduct on-site signals interception, deploy rogue wireless infrastructure, and combine wireless compromise with credential-based follow-on access to internal systems. The technology at risk was standard enterprise and hotel-grade IEEE 802.11 wireless networking, including guest Wi-Fi portals, hotel business-centre networks, and, in some cases, semi-private conference Wi-Fi provisioned for event delegates.

The stated objective of the operation was to obtain credentials and unauthorised access to sensitive anti-doping information, including athlete whereabouts data, therapeutic-use exemption (TUE) records, and ongoing investigation files, some of which was later leaked publicly by an affiliated persona. The incident illustrates how physical proximity to a target's travel and lodging patterns can be exploited when wireless networks are not designed to resist a determined, on-site adversary.

The operation formed part of a broader pattern of activity against the global anti-doping movement following the 2016 disclosure of Russian state-sponsored doping, which had resulted in sanctions against Russian athletes and sporting bodies. Anti-doping organisations therefore represented a high-value intelligence target, and officials travelling to hearings, sample-collection events, and federation meetings were repeatedly exposed to hotel and venue Wi-Fi in multiple countries, widening the attack surface available to a persistent adversary.

1.1 Timeline of Key Events

Date / Period	Event
2016 (Rio Olympic Games)	Alleged close-access wireless targeting of anti-doping officials and event delegates connected to hotel and venue Wi-Fi in Rio de Janeiro.
2016–2017 (Lausanne)	Further alleged close-access operations against Wi-Fi networks used by officials of international sporting federations and the Court of Arbitration for Sport in Lausanne.
2016–2018	Confidential athlete data, including therapeutic-use exemption records, obtained through related intrusions was progressively leaked online by an affiliated persona.
October 2018	The United States Department of Justice unseals an indictment publicly attributing the close-access wireless operations to state-sponsored military intelligence officers.

2. Identification of Wireless Vulnerabilities

A review of the incident and comparable hotel/event Wi-Fi environments identifies the following wireless-specific vulnerabilities that would have enabled the type of close-access compromise alleged in this case:

Vulnerability Area	Description	Relevant Standard / Control
Open / Shared Public Wi-Fi Authentication	Hotel and conference Wi-Fi networks used by officials typically relied on a single shared passphrase or no authentication at all, allowing any nearby device to join the same broadcast domain as the target.	WPA2/WPA3-Enterprise, IEEE 802.1X
Absence of Mutual Authentication (EAP-TLS)	Client devices could not verify that the access point they joined was the legitimate hotel network, enabling evil-twin or rogue access point impersonation and credential interception.	EAP-TLS with certificate pinning
Credential Capture over Wireless	Login pages and internal portals used by officials to check email or access case files were reachable without enforced end-to-end encryption, allowing session and credential interception by a close-access adversary.	Mandatory HTTPS/TLS, HSTS
No Multi-Factor Authentication (MFA)	Single-factor username/password access to anti-doping and medical databases meant that a captured credential alone was sufficient for unauthorised access.	Hardware token or app-based MFA (FIDO2/TOTP)

Unmanaged / Unhardened Endpoints	Laptops and mobile devices connected to untrusted hotel networks without device certificates, endpoint detection, or a VPN client, exposing them directly to the local wireless segment.	Endpoint Detection & Response (EDR), device certificates
No Split-Tunnel Restriction / VPN Enforcement	Where VPNs existed, they were not enforced for all traffic, leaving some application traffic exposed on the local wireless network (split tunnelling).	Always-on full-tunnel VPN policy
Weak Travel-Security Awareness	Officials were not routinely briefed on close-access wireless threats, leading to use of hotel Wi-Fi for sensitive medical and case-related work without additional safeguards.	Travel-security policy and user-awareness training

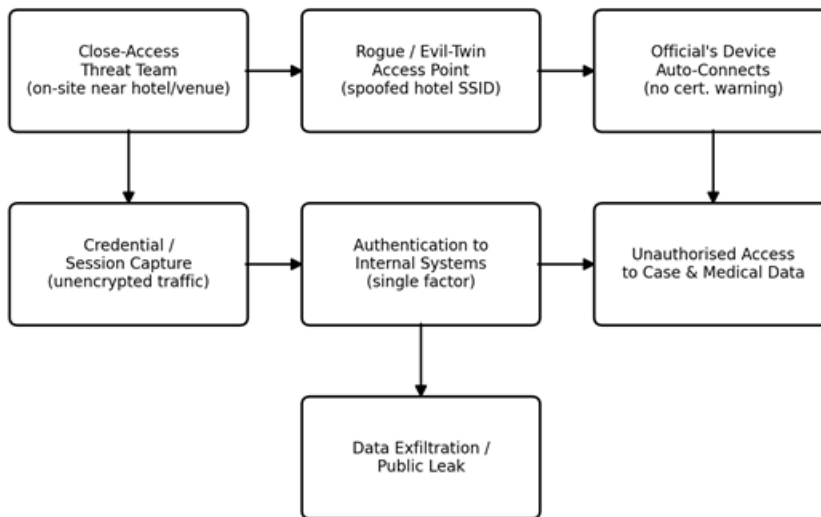
Taken together, these vulnerabilities describe an environment in which the wireless layer itself provided little resistance to a physically present adversary: any device within radio range of the hotel or venue access points could attempt authentication, impersonate the network, or passively observe unencrypted traffic, and no additional layer (VPN, MFA, device certificate) was consistently enforced to compensate.

3. Risk, Impact, and Root-Cause Analysis

3.1 Attack Vector

The most probable attack chain involved close-access personnel either passively monitoring open or weakly secured hotel Wi-Fi traffic, or actively standing up a rogue access point broadcasting an SSID similar or identical to the legitimate hotel network. Officials' devices, configured to automatically reconnect to previously used or trusted-looking network names, would associate with the rogue access point without a security warning. From this position, the adversary could intercept login credentials for webmail and case-management portals, redirect DNS queries, or serve fraudulent certificate/update prompts to deliver further access tools onto the device.

Figure 1: Close-Access Wireless Attack Chain — Anti-Doping Officials Incident, 2016



As shown in Figure 1, the compromise progresses through a predictable chain: physical proximity enables wireless impersonation, which enables credential capture, which enables authenticated access to internal systems, culminating in exposure of sensitive data. Each arrow in the chain represents a point at which a specific control — mutual authentication, encrypted transport, multi-factor authentication, or monitoring — could have interrupted the attack before it reached the next stage, which is the basis for the layered recommendations in Section 4.

3.2 Root Causes

- Reliance on network-level trust (being “on the hotel Wi-Fi”) rather than end-to-end, mutually authenticated connections.
- No organisational requirement for travelling staff to use a corporate VPN or MFA when accessing sensitive systems from untrusted networks.
- Absence of a travel-security policy addressing wireless risk for personnel handling medical and investigative data.
- No monitoring or anomaly detection capable of flagging logins to sensitive systems from unexpected or high-risk geographic/network origins.

3.3 Impact Analysis

Operational impact: compromised credentials could allow continued, undetected access to anti-doping case files and internal communications, undermining active investigations. Privacy impact: exposure of athlete medical records, including therapeutic-use exemptions, constitutes a serious breach of sensitive personal health information. Legal and regulatory impact: unauthorised disclosure of medical data raises exposure under data-protection regimes such as the GDPR, given the Lausanne-based (Swiss/EU-adjacent) operations, and may breach confidentiality obligations owed to athletes. Reputational impact: public leaking of confidential anti-doping material, as occurred in the related case, damages trust in the

impartiality and security of the anti-doping system. Financial impact includes incident-response costs, legal exposure, and potential remediation of affected case-management infrastructure.

Risk	Likelihood	Impact	Overall Rating	Primary Affected Asset
Credential theft via hotel Wi-Fi	High	High	Critical	Anti-doping case management system
Evil-twin / rogue AP impersonation	Medium	High	High	Official laptops and mobile devices
Unauthorised access to medical records	Medium	Very High	Critical	Athlete medical / TUE data
Session hijacking on unsecured portals	Medium	Medium	Medium	Web-based reporting portals
Reputational damage from disclosure	Medium	High	High	Organisational trust / athlete privacy

3.4 Comparison with Related Wireless Incidents

The anti-doping case shares its root pattern — trust placed in a physically local wireless network — with several other publicly documented incidents. The DarkHotel campaign similarly abused hotel Wi-Fi to deliver malware to travelling executives through fraudulent update prompts, while the 2018 attempted intrusion against the Organisation for the Prohibition of Chemical Weapons used close-access equipment to target enterprise Wi-Fi from a vehicle parked outside the building. What distinguishes the anti-doping case is the sensitivity of the target data (athlete medical and investigative records) and the fact that the campaign spanned multiple countries and events, indicating a sustained, resourced operation rather than a single opportunistic attack. This comparison reinforces that close-access wireless risk is not unique to this organisation and should be addressed through standing policy rather than one-off, event-specific measures.

4. Security Recommendations and Mitigation Measures

4.1 Network and Authentication Controls

1. Mandate WPA2-Enterprise or WPA3-Enterprise with IEEE 802.1X and EAP-TLS for any organisation-managed wireless network used at events, replacing shared-passphrase or open guest access for staff.

2. Require certificate-based mutual authentication so client devices can verify the legitimate access point before joining, reducing exposure to evil-twin and rogue-AP attacks.
3. Where hotel or third-party Wi-Fi cannot be controlled, treat it as fully untrusted and never as a substitute for a managed network.

4.2 Endpoint and Access Controls

4. Enforce an always-on, full-tunnel VPN on all staff devices before any access to organisational systems from travel or hotel networks.
5. Require hardware-token or app-based multi-factor authentication (e.g., FIDO2 security keys or TOTP) for all access to case-management, email, and medical-record systems.
6. Deploy endpoint detection and response (EDR) and device certificates so only managed, compliant devices can connect to sensitive resources.

4.3 Monitoring and Governance

7. Implement wireless intrusion detection (WIDS) capability, or portable rogue-AP detection tools, for officials attending high-profile events.
8. Log and monitor authentication attempts to sensitive systems for anomalous network origin, device fingerprint, or geolocation, with alerting for high-risk sign-ins.
9. Introduce a formal travel-security policy for personnel handling medical or investigative data, including a pre-travel briefing on close-access wireless threats.

4.4 User Awareness

10. Train officials to disable automatic Wi-Fi reconnection, verify network names with venue/hotel staff, and treat certificate or software-update warnings on unfamiliar networks as a stop signal.
11. Encourage use of cellular data or a trusted personal hotspot as a default alternative to hotel or conference Wi-Fi when handling sensitive information.

5. Report Quality, Evidence, and Presentation

This report has been structured to align with each assessed criterion: incident background, vulnerability identification, risk and root-cause analysis, and mitigation recommendations, supported by a vulnerability table and a risk-rating summary. All findings are based on publicly reported facts from the referenced indictment and related open-source reporting; no confidential or unverified information has been used.

5.1 Overall Risk-Rating Summary

Based on the analysis in Section 3, the environment is rated as having an overall CRITICAL wireless-security risk prior to remediation, driven primarily by the sensitivity of anti-doping medical data and the demonstrated intent and capability of a state-sponsored close-access threat actor. Implementation of the Section 4 recommendations — in particular enterprise wireless authentication, mandatory VPN/MFA, and travel-security policy — would reduce the residual risk to LOW to MEDIUM.

5.2 References

United States Department of Justice, Office of Public Affairs. (2018). U.S. charges Russian GRU officers with international hacking and related influence and disinformation operations. Press release.

Federal Bureau of Investigation. (2018). Indictment: United States of America v. Aleksei Sergeyevich Morenets, et al., District of New Jersey.

World Anti-Doping Agency (WADA). (2016–2018). Statements on cyberattacks against WADA and anti-doping systems.

IEEE Standards Association. IEEE 802.11 and 802.1X standards documentation.

National Institute of Standards and Technology (NIST). SP 800-153: Guidelines for Securing Wireless Local Area Networks (WLANs).

Appendix A: Glossary of Key Terms

Term	Definition
Close-Access Operation	A cyber operation in which personnel or equipment are physically positioned near a target to intercept or interfere with local networks, such as Wi-Fi, that cannot be reached remotely.
Evil-Twin Access Point	A rogue wireless access point configured to broadcast the same or a very similar network name (SSID) as a legitimate network, tricking devices into connecting to it.
WPA2/WPA3-Enterprise	Wireless security modes that require each user or device to authenticate individually (typically via 802.1X) rather than sharing a single network passphrase.
IEEE 802.1X	A port-based network access control standard used to authenticate devices before granting them access to a wired or wireless network.
EAP-TLS	An Extensible Authentication Protocol method that uses digital certificates for mutual authentication between the client device and the network.
Multi-Factor Authentication (MFA)	An authentication method requiring two or more independent factors (e.g., password plus hardware token) before granting access to a system.
Therapeutic-Use Exemption (TUE)	Official authorisation allowing an athlete to use a prohibited substance or method for a legitimate medical reason; TUE records contain sensitive medical information.

Wireless Intrusion Detection System (WIDS)	A system that monitors radio-frequency traffic to detect rogue access points, evil-twin attacks, and other unauthorised wireless activity.
---	--